

BreakingVali

EigenDA

Threat Model Assessment

May, 2026

Contents

Introduction

This report presents the findings of an independent threat model assessment conducted against EigenDA, the data availability service built as an Actively Validated Service (AVS) on EigenLayer. The assessment was performed using an asset-centric methodology aligned with the STRIDE framework, systematically identifying threats across on-chain governance structures, off-chain infrastructure components, protocol-level security mechanisms, and operational practices.

Disclaimer

The assessors make all effort but hold no responsibility for the findings of this threat model assessment. No guarantees are provided relating to the function of the smart contracts or off-chain components in scope. No judgements are made on, or security review provided regarding, the underlying business model or the individuals involved in the project.

Document Structure

The first section provides an abstract summarizing the overall assessment scope and key findings. This is followed by the methodology used, a detailed overview of the system architecture, and a comprehensive threat catalog organized by category. Each threat is assigned a severity classification, a verification status, a BVSS score, and a mapping to supporting proof-of-concept evidence. The report concludes with cross-cutting observations, recommended controls, limitations, and address mapping appendices.

Overview

EigenDA is a Data Availability service built on top of Ethereum using the EigenLayer restaking protocol. Operators register through the RegistryCoordinator, receive stake delegations across multiple quorums, and participate in data availability attestation through BLS signature aggregation. The system architecture comprises an on-chain governance layer, a dispersal layer, a storage and retrieval layer, and a certification pipeline.

Abstract

This threat model assessment identifies, classifies, and validates security threats within the EigenDA data availability system deployed on Ethereum Mainnet. The assessment encompasses 42 discrete threat scenarios derived from systematic analysis of 20 system actors and 47 assets, supported by 32 proof-of-concept validations.

The threat catalog reveals critical concentration risks at multiple system layers. On-chain governance authority converges on a single 3-of-4 Gnosis Safe multisig that simultaneously controls 10 contract administrative roles and proxy upgrade capabilities. The data availability path exhibits serial single-points-of-failure: one registered relay, one disperser, per-blob single-relay assignment, and 98.65% dispersal traffic concentration on a single account. Slashing infrastructure remains unwired (`AllocationManager.getOperatorSetCount = 0`), creating an asymmetric incentive environment. Authentication and rate-limiting controls are absent across relay, disperser V2, and proxy REST interfaces.

Of the 42 identified threats, 32 are verified through on-chain or live-endpoint evidence, 9 are code-verified through source analysis, and 1 is partially verified. Three previously identified threats (payment replay, signature replay, payment metadata manipulation) have been confirmed as remediated. Eight threats score BVSS 30.0 or above, with the relay single-point-of-failure (BVSS 80.0) and disperser V2 rate-limit absence (BVSS 50.0) representing the highest quantified risks.

Security Assessment Summary

Scope

The assessment targets EigenDA as deployed on Ethereum Mainnet (chain ID 1), encompassing on-chain smart contracts, off-chain infrastructure (dispenser, relay, proxy), governance structures, operator quorum mechanics, and the data availability certification pipeline.

The following on-chain contracts were assessed:

Contract	Address
EigenDAServiceManager	0x870679E138bCdF293b7Ff14dD44b70FC97e12fc0
RegistryCoordinator	0x0BAAc79acD45A023E19345c352d8a7a83C4e5656
EjectionManager	0x130d8EA0052B45554e4C99079B84df292149Bd5E
PaymentVault	0xb2e7ef419a2A399472ae22ef5cFcCb8bE97A4B05
ThresholdRegistry	0xdb4c89956eEa6F606135E7d366322F2bDE609F15
CertVerifierRouter	0x1be7258230250Bc6a4548F8D59d576a87D216C12
RelayRegistry	0xD160e6C1543f562fc2B0A5bf090aED32640Ec55B
DispenserRegistry	0x78cb05379a3b66E5227f2C1496432D7FFE794Fad
ProxyAdmin	0x8247Ef5705d3345516286b72bFe6D690197c2E99

Off-chain components assessed include: Dispenser V2 gRPC service, Relay GetBlob/GetChunks endpoints, Proxy REST sidecar, and DataAPI monitoring feeds.

Approach

The assessment employed an asset-centric threat modeling methodology. Each system actor (20 total) and asset (47 total) was cataloged with privilege relationships mapped. Threat scenarios were derived by examining abuse potential at each privilege boundary. Threats are scored using the Blockchain Vulnerability Scoring System (BVSS) on a 0–100 scale.

For on-chain components, analysis focused on governance privilege concentration, proxy upgrade authority, multisig configurations, pauser/unpauser role separation, and ejector privilege distribution. On-chain state was queried directly for quorum parameters, stake distributions, and operator set configurations.

For off-chain components, analysis targeted authentication mechanisms, rate-limiting controls, gRPC interceptor chains, endpoint exposure defaults, and infrastructure provider concentration. Live endpoint probing was conducted against mainnet relay and dispenser services.

The following evidence sources were used:

Ref	Source	Coverage
[A]	Actor/Asset Catalog (eigenda_assets.json)	20 actors, 47 assets with privilege mappings
[T]	Threat Catalog (threats.json)	42 threats with BVSS scores and verification
[S]	Quorum Operator Stakes (.numbers)	Stake distribution across Q0, Q1, Q2
[P#NN]	PoC Reports (new_poc/NN-*/)	32 validated proof-of-concept artifacts

Coverage Limitations

All on-chain observations reflect state at the time of evidence collection. Subsequent contract upgrades, parameter changes, or governance actions may alter the threat landscape. Q1 operator count varies by measurement source (56 via asset catalog versus 62 via DataAPI signing-info). The dispersal concentration HHI measurement is derived from a 1-hour window sample. The runtime default value of `TolerateMissingAnchorSignature` could not be confirmed from available evidence sources.

Findings Summary

The assessment identified a total of 42 threat scenarios. Categorized by verification status and severity:

Category	Count	BVSS ≥ 30	High Sev	Medium Sev	Resolved
Governance & Access Control	7	3	0	2	0
Data Availability & Infrastructure	9	3	1	0	0
Authentication & Rate Limiting	4	2	0	0	0
Protocol & Cryptographic Integrity	7	0	0	0	3
Economic & Incentive	6	2	2	1	0
Code-Verified Only	9	—	—	—	—

Detailed Findings

This section provides a detailed description of the threat scenarios identified within the EigenDA components in scope. Each threat has a severity classification determined from the impact and likelihood using the matrix given in Appendix A.

Each threat is assigned a verification status:

Verified: the threat was validated through on-chain state queries, live endpoint probing, or evidence artifact analysis.

Code-Verified: the threat was identified through source code analysis and cataloged for reference.

Partial: the threat has constrained reproducibility due to multi-factor prerequisites.

Resolved: the threat was previously identified and remediation has been confirmed through code-level regression analysis.

Summary of Findings

ID	BVSS	Description	Severity	Status	PoC
EDA-D06	80.0	Relay Single Point of Failure (1 Registered Relay)	Critical	Verified	P#01
EDA-D05	60.0	Single Relay Assignment Per Blob Degrades Availability	Critical	Verified	P#01
EDA-D03	50.0	Disperser V2 gRPC Rate-Limit Interceptor Not Registered	Critical	Verified	P#20
EDA-E04	45.0	Dispersal Usage Concentrated in Single Account (98.65%)	High	Verified	P#09
EDA-E02	40.0	Single 3-of-4 Multisig Controls 10 Contract Admin Roles	High	Verified	P#03
EDA-T09	36.0	Ejector Role Abuse for Honest Operator Removal	High	Verified	P#05
EDA-E03	36.0	Operator Stake Concentration Enables Threshold Breach	High	Verified	P#14
EDA-S06	35.0	Governance 3-of-4 Multisig Key Compromise	High	Verified	P#03
EDA-P01	32.0	Slashing Not Implemented — Incentive Asymmetry	High	Verified	P#30
EDA-D07	30.0	Relay GetBlob Unauthenticated Access	Medium	Verified	P#07
EDA-S01	28.0	Batcher Identity Spoofing via Unauthenticated Proxy	Medium	Verified	P#07
EDA-D09	28.0	Disperser/Relay Registration Permissioned (SPOF)	Medium	Verified	P#01
EDA-D10	28.0	Unauthenticated Bulk POST Overloads Proxy	Medium	Verified	P#25
EDA-T07	27.0	CertVerifier Logic Replacement via ProxyAdmin	Medium	Verified	P#02
EDA-D08	24.5	Pauser Role Halts Operator Registration/Updates	Medium	Verified	P#04
EDA-S03	21.0	Cross-Chain Signature Replay	Medium	Verified	Code
G-CON-03	18.9	Operator Infra Concentrated in Few Hosting Providers	High	Verified	P#16
EDA-T12	18.0	Anchor Signature Conditionally Optional in Proto	Medium	Verified	Code
EDA-E01	16.0	Anchor Verification Disabled by Flag	Low	Verified	Code
G-CON-05	15.0	Rewards Initiator Safe Omitted from Privilege Matrix	Medium	Verified	P#17
EDA-D01	14.7	Ethereum RPC Failure Disrupts Write/Read Paths	Low	Verified	P#21
EDA-P02	14.7	DAS Absence — Quorum Trust Dependency	Medium	Verified	P#31
EDA-D11	14.4	Sub-Threshold Signing Stake in Attestation	Low	Verified	P#11
EDA-D12	14.4	Dead Operators (11 Chunk-Serving 0%)	Low	Verified	P#12
EDA-D13	10.5	gRPC Message Size Mismatch (4MB vs 16MB)	Low	Verified	P#13
EDA-T06	7.5	KV Store Checksum Not Implemented	Low	Verified	P#06
EDA-D04	7.2	Encoding Failure With No Fallback Path	Low	Verified	P#15
G-OPS-02	6.0	Dormant churnApprover EOA	Medium	Verified	P#18
EDA-T02	6.0	Relay Response Data Tampering	Low	Verified	Code
EDA-T11	3.6	Payment Replay (Resolved)	Informational	Resolved	P#22
EDA-S05	3.0	StoreChunksRequest Signature Replay (Resolved)	Informational	Resolved	P#22

ID	BVSS	Description	Severity	Status	PoC
EDA-T03	3.0	Payment Metadata Manipulation (Resolved)	Informational	Resolved	P#22
EDA-T10	—	Attestation Data Manipulation (Constrained)	Low	Partial	P#26

EDA-D06	Relay Single Point of Failure	
Asset	RelayRegistry (0xD160e6C1543f562fc2B0A5bf090aED32640Ec55B)	
Status	Verified: Evidence in P#01	
Severity: Critical	Impact: High	Likelihood: High

Description

Mainnet operates a single registered relay (RelayRegistry.nextRelayKey() = 1). The sole registered relay (relay-0-mainnet-ethereum.eigenda.xyz:443, on-chain key 0xe8437B66E834B7CdC90cC5D98B8DD6e636b37D7a) represents a complete single point of failure for the blob retrieval path. The RelayRegistry contract exposes addRelayInfo() but provides no deletion function, creating an append-only registry that currently contains exactly one entry.

Compounding this, the NumRelayAssignment default value is 1, meaning each blob is assigned to exactly one relay. A failure or compromise of this single relay results in total retrieval path unavailability for all blobs.

BVSS Score: 80.0. The highest quantified risk in the threat catalog.

Recommendations

Deploy multiple relay instances and register them in the RelayRegistry. Enable per-blob multi-relay assignment by increasing NumRelayAssignment. Implement per-client retrieval quotas to prevent individual relay exhaustion.

EDA-D03	Disperser V2 gRPC Rate-Limit Interceptor Not Registered	
Asset	Disperser V2 (disperser.eigenda.xyz:443)	
Status	Verified: Evidence in P#20	
Severity: Critical	Impact: High	Likelihood: High

Description

The Disperser V2 gRPC interceptor chain (grpc.ChainUnaryInterceptor) contains only a metrics interceptor with zero rate-limit interceptors registered. Burst testing with 50 and 100 parallel GetBlobStatus calls produced 100% normal responses with zero RESOURCE_EXHAUSTED rejections. A residual RateConfig structure exists in the source code but is not wired to the V2 server runtime. gRPC reflection confirms the full API surface (DisperseBlob, GetBlobStatus, GetPaymentState, GetValidatorSigningRate, GetBlobCommitment) is enumerable by any unauthenticated client.

Recommendations

Register rate-limit interceptors for all V2 gRPC methods in the ChainUnaryInterceptor chain. Implement cost-based throttling that accounts for computational weight of each endpoint. Remove or wire the dead RateConfig to prevent configuration drift.

EDA-E02	Single 3-of-4 Multisig Controls 10 Contract Admin Roles	
Asset	DA Ops Safe (0x002721B4790d97dC140a049936a A710152Ba92D5)	
Status	Verified: Evidence in P#03	
Severity: High	Impact: High	Likelihood: Medium

Description

The DA Operations Safe (Gnosis Safe v1.4.1, threshold 3-of-4, all 4 signers EOA) simultaneously holds the owner role on EigenDAServiceManager, RegistryCoordinator, EjectionManager, PaymentVault, ThresholdRegistry, CertVerifierRouter, RelayRegistry, DisperserRegistry, ProxyAdmin, and AccessControl DEFAULT_ADMIN_ROLE, plus a function-call capability on PaymentVault.setReservation(). The Safe nonce is 39 with the most recent execTransaction dated 2026-04-03. Compromise of 3 signer keys enables modification of operational policy, payment authorization, certificate verification logic, and proxy implementations in a single governance action.

Recommendations

Decompose Safe roles across multiple signer sets with non-overlapping membership. Enforce timelock delays on critical operations (proxy upgrades, threshold changes, ejector configuration). Mandate hardware signing for all Safe signers. Implement a signer rotation policy.

EDA-P01	EigenDA Operator Slashing Not Implemented	
Asset	EigenLayer AllocationManager (0x948a420b8CC1d6BFd0B6087C2E7 c344a2CD0bc39)	
Status	Verified: Evidence in P#30	
Severity: High	Impact: High	Likelihood: Medium

Description

The EigenLayer AllocationManager contract is active on mainnet but reports getOperatorSetCount = 0, confirming that EigenDA's AVS is not connected to the slashing infrastructure. The slash capability (ASSET-042) lifecycle is classified as unwired. This creates an environment where operators can engage in dishonest behavior—including submitting BLS signatures without storing or serving chunk data—without economic penalty. Prober data identifies 11 operators with 0% chunk-serving rates, of which 8 submit BLS signatures (free-rider candidates).

Recommendations

Activate slashing circuit or equivalent punitive mechanism via AllocationManager integration. Deploy automated free-rider detection that cross-correlates BLS signing rates with chunk-serving probe results.

EDA-D08	Pauser/Unpauser Single Point of Failure
----------------	--

Asset	PauserRegistry (P1/P2/P3 Safes)	
Status	Verified: Evidence in P#04, P#08	
Severity: Medium	Impact: High	Likelihood: Medium

Description

Pause capability is distributed across three Safes (P1: 1-of-2 contract owners, P2: 3-of-6 EOA, P3: 1-of-7 with 6 EOA + 1 nested Safe). However, unpause authority is concentrated solely in P1. The weakest pauser (P3) has 4 of 6 EOA owners with nonce=0, indicating potential dormancy or unverifiable hardware wallet status. A single key compromise of any P3 signer enables system-wide pause via `pauseAll()`. The DA Ops Safe 4 signers and Pauser Safe 13 signers have zero overlap, confirming governance/pause authority separation at the EOA level.

Recommendations

Evaluate increasing the P3 threshold above 1-of-7. Implement periodic liveness checks for pauser signers. Consider adding a secondary unpause path to eliminate the P1 SPOF.

EDA-T09	Ejector Role Abuse for Honest Operator Removal	
Asset	EjectionManager (0x130d8EA0052B45554e4C99079B84df292149Bd5E)	
Status	Verified: Evidence in P#05	
Severity: High	Impact: High	Likelihood: Medium

Description

Three addresses hold ejector privileges, but 100% of the 150 ejection calls over 16 months originated from two EOAs (89 calls / 59% and 61 calls / 41% respectively). A SafeProxy ejector (0x338477ff...) has never executed a single call. Single EOA compromise enables forced ejection of up to 33.33% of quorum total stake within a 3-day window (quorumEjectionParams: 259200 sec / 3333 BIPS), with ejected operators blocked from re-registration for 3 days.

Recommendations

Transition ejector authority to multisig-only execution. Require evidence-based ejection criteria with on-chain verification. Introduce execution delay for ejection actions.

EDA-D07	Relay GetBlob Unauthenticated Access	
Asset	Relay (relay-0-mainnet-ethereum.eigenda.xyz:443)	
Status	Verified: Evidence in P#07	
Severity: Medium	Impact: High	Likelihood: Medium

Description

The relay GetBlob endpoint accepts unauthenticated gRPC calls. Testing via grpcurl confirms requests without credentials receive NotFound responses (not Unauthorized), indicating no authentication layer exists. Only a global token-bucket rate limiter is present with no per-client controls.

Recommendations

Implement per-client authentication and quota enforcement. Deploy adaptive rate limiting that accounts for blob size.

EDA-E03	Operator Stake Concentration Enables Threshold Breach	
Asset	Quorum Operator Set (Q0/Q1/Q2)	
Status	Verified: Evidence in P#14, [S]	
Severity: High	Impact: High	Likelihood: Medium

Description

Stake distribution analysis from source [S] reveals: in Q0 (ETH), the top 3 operators control 39.80% of stake, exceeding the 33% safety threshold; top 5 control 55.25%, exceeding the 55% confirmation threshold. In Q1 (EIGEN), top 3 hold 35.60%. Q2 (Custom) exhibits extreme concentration with a single operator (AltLayer) holding 52.55% of total stake. Collusion among 3 operators in any major quorum is sufficient to compromise safety guarantees.

Quorum	Records	Top-3	Top-4	Top-5	Safety 33%	Liveness 45%	Majority 50%
Q0 (ETH)	120	39.80%	48.16%	55.25%	Rank 3	Rank 4	Rank 5
Q1 (EIGEN)	56	35.60%	44.00%	51.70%	Rank 3	Rank 5	Rank 5
Q2 (Custom)	6	100%	100%	100%	Rank 1	Rank 1	Rank 1

Recommendations

Enforce provider and stake concentration caps. Incentivize operator diversity through differential reward mechanisms.

G-CON-03	Operator Infrastructure Concentrated in Few Hosting Providers
-----------------	--

Asset	Operator Node Infrastructure	
Status	Verified: Evidence in P#16	
Severity: High	Impact: High	Likelihood: Medium

Description

IP-to-ASN mapping cross-correlated with stake distribution reveals: In Q0, the top-5 providers (Amazon AWS 21.78%, P2P.org 20.43%, OVH SAS 15.67%, DigitalOcean 13.67%) account for 82.73% of stake-weighted infrastructure. In Q1, a single SaaS provider (Herd) hosts 41.87% of stake. Single-provider failure scenarios: Herd down results in Q1 signing at 58% (confirmation threshold 55% at risk); AWS down results in Q0 signing at 78% (safety threshold 33% potentially breached).

Recommendations

Enforce provider/ASN concentration caps in operator registration. Incentivize geographic and provider diversification through governance policy.

Cross-Cutting Observations

1. Privilege Concentration Asymmetry

The DA Ops Safe simultaneously holds administrative authority over 9 contracts and the ProxyAdmin, while the pause/unpause structure is distributed across 3 Safes with the unpauser as a single point of failure. A separately governed Rewards Initiator Safe (3-of-4, v1.3.0, zero signer overlap) was absent from prior privilege matrices, creating a governance blind spot.

2. Serial Single-Points-of-Failure in Availability Path

The data availability path contains SPOFs connected in series: a single registered relay, per-blob single-relay assignment, 98.65% dispersal traffic concentration on one account (HHI = 9,731), and a single-endpoint proxy RPC configuration. Failure at any point results in full or partial availability loss.

3. Incentive Vacuum

The absence of a wired slashing mechanism (`AllocationManager.getOperatorSetCount = 0`) combined with 8 potential free-rider operators (BLS-signing but chunk-serving 0%) creates an environment where rational operators may minimize resource expenditure without economic consequence.

4. Authentication and Resource Control Imbalance

The relay `GetBlob` endpoint, Disperser V2 gRPC interface, and proxy REST API all lack per-client authentication. Payment-based authorization protects write-path operations but leaves the read-path entirely unprotected. The proxy default configuration (0.0.0.0:3100, no auth flags) contradicts operational assumptions about sidecar isolation.

5. Testnet-Mainnet Divergence

Sepolia governance is structurally weaker than mainnet (EOA-owned contracts, Safe threshold=1), while operator distribution is synthetically uniform (9 operators at 11.11% each). Mainnet-specific operational threats cannot be reproduced or tested on the testnet.

Recommended Controls

Priority	Target	Control	Source
Immediate	EDA-D06/D05	Multi-relay deployment; per-blob multi-relay assignment; per-client quota	[T]
Immediate	EDA-D07	Per-client auth/quota on relay GetBlob; adaptive rate limiter	[T]
Immediate	EDA-D03	V2 rate-limit interceptor; cost-based throttling	[T]
High	EDA-E02/S06	Safe role decomposition; timelock; hardware signing; rotation	[T]
High	EDA-T09	Ejector multisig; evidence-based ejection; delay	[T], P#05
High	EDA-P01	Slashing circuit activation; free-rider detection	[T], P#12
Medium	G-CON-03/E03	Provider/ASN caps; operator diversification	[T]
Medium	EDA-E04	Top-account monitoring; reservation governance	[T]
Medium	EDA-D13	MaxCallRecvMsgSize alignment	P#13
Medium	EDA-D01	Multi-RPC proxy support; deep health checks	P#21

Appendix A: Vulnerability Severity Classification

This assessment classifies vulnerabilities based on their potential impact and likelihood of occurrence. The total severity of a vulnerability is derived from these two metrics based on the following matrix.

Impact \ Likelihood	Low	Medium	High
High	Medium	High	Critical
Medium	Low	Medium	High
Low	Low	Low	Medium

Table 1: Severity Matrix — How the severity of a vulnerability is given based on the impact and the likelihood of a vulnerability.

Appendix B: Contract and Actor Address Mapping

Role	Address	Ref ID
DA Ops Safe (3-of-4, v1.4.1)	0x002721B4790d97dC140a049936aA710152Ba92D5	ACTOR-001
Rewards Initiator Safe (3-of-4)	0x178eeeA9E0928dA2153A1d7951FBe30CF8371b8A	ACTOR-002
Pauser P1 / Unpauser	0x369e6F597e22EaB55fFb173C6d9cD234BD699111	ACTOR-003
Ejector EOA #1	0xd2ee81cf07b12140c793fce5b26313cdd9d78ea8	ACTOR-006
Ejector EOA #2	0x8642473a123fe33b0aae90bd8604ea1029417236	ACTOR-007
churnApprover (dormant)	0xe0550117Cb066D3b330eBd764B0d75D3BA378734	ACTOR-009
Dominant Dispersing EOA	0x41fa832fad553c3b92976344d44b3548517679ac	ACTOR-010
EigenLabs Disperser	disperser.eigenda.xyz:443	ACTOR-013
EigenLabs Relay 0	relay-0-mainnet-ethereum.eigenda.xyz:443	ACTOR-014
AltLayer (Q2 dominant)	0x71C6F7Ed8C2d4925d0bAf16f6A85BB1736D412eb	ACTOR-016
AllocationManager (unwired)	0x948a420b8CC1d6Bfd0B6087C2E7c344a2CD0bc39	ACTOR-018
EigenDAServiceManager	0x870679E138bCdf293b7Ff14dD44b70FC97e12fc0	ASSET-002
RegistryCoordinator	0x0BAAc79acD45A023E19345c352d8a7a83C4e5656	ASSET-003
EjectionManager	0x130d8EA0052B45554e4C99079B84df292149Bd5E	ASSET-004
PaymentVault	0xb2e7ef419a2A399472ae22ef5cFcCb8bE97A4B05	ASSET-005
ThresholdRegistry	0xdb4c89956eEa6F606135E7d366322F2bDE609F15	ASSET-006
CertVerifierRouter	0x1be7258230250Bc6a4548F8D59d576a87D216C12	ASSET-007
RelayRegistry	0xD160e6C1543f562fc2B0A5bf090aED32640Ec55B	ASSET-008
DisperserRegistry	0x78cb05379a3b66E5227f2C1496432D7FFE794Fad	ASSET-009
ProxyAdmin	0x8247Ef5705d3345516286b72bFe6D690197c2E99	ASSET-010

End of Report